

1. EXECUTIVE SUMMARY

A formal security, transport, dependency, and production-readiness audit was performed on TopVeda at the conclusion of Phase 2. The audit verified zero vulnerabilities across all 521 npm dependencies, verified strict transport security (HTTPS/HSTS), verified zero credential exposure, and confirmed zero occurrences of dangerous HTML or dynamic script execution.

Final Assessment: PASS — Project is approved to proceed to Phase 3.

2. TECHNOLOGY & SCOPE

- Framework: Next.js 16.3.4 (App Router, React 19) | Runtime: Cloudflare Workers via Vinext
- Language: TypeScript 5.x (Strict Typechecking) | Styling: Tailwind CSS 4.x
- Scope: Public Landing Page, Layout, Brand System, SEO Metadata, and Client Modals.
- Not in Scope (Phase 2): Real Supabase Auth, database queries, payments, and file uploads.

3. SECURITY TEST RESULTS MATRIX

ID	Control / Test Description	Status	Severity	Evidence / Verification Notes
SEC-01	Transport Security (HTTPS / HSTS)	PASS	Low	All asset & API URLs enforce HTTPS; production canonical set to topveda.in
SEC-02	Secrets & Credential Isolation	PASS	Critical	Zero API keys, private tokens, or database secrets committed in Git
SEC-03	XSS & HTML Injection Protection	PASS	High	0 occurrences of dangerouslySetInnerHTML or dynamic code eval()
SEC-04	Open Redirect Protection	PASS	Medium	All navigation and window.location calls restricted to internal routes
SEC-05	Security Headers Configuration	PASS	Medium	HSTS, X-Frame-Options (SAMEORIGIN), nosniff, and Permissions-Policy active
SEC-06	Dependency Vulnerability Audit	PASS	High	npm audit verified 0 vulnerabilities across 521 packages
SEC-07	TypeScript & Build Validation	PASS	High	tsc --noEmit (0 errors) & Next.js production build (92 routes) passed
SEC-08	Accessibility & Keyboard Traps	PASS	Low	Focus rings visible, Escape key handlers active on all modals
SEC-09	User Password Hashing & Salts	N/A	Critical	Authentication backend not in Phase 2 scope; mandatory for Phase 3
SEC-10	Row Level Security (RLS) Policies	N/A	Critical	Direct database operations not connected in Phase 2; mandatory for Phase 3
SEC-11	Server-Side RBAC / IDOR Protection	N/A	Critical	Roles are client-simulated in Phase 2; mandatory server gating in Phase 3
SEC-12	Payment Webhook Signature Verification	N/A	Critical	No payment gateway in Phase 2; mandatory HMAC verification in Phase 4

4. PHASE 3 MANDATORY SECURITY REQUIREMENTS

- Before enabling real user registration, login, and database persistence in Phase 3, the following security controls are strictly required:
- 1. Password Security:** Use Supabase managed Argon2id/bcrypt hashing. Never store or log plaintext passwords. Enforce cryptographically random, single-use reset tokens with "d1-hour expiration.
 - 2. Session Management:** Store session tokens in HttpOnly, Secure, SameSite=Lax cookies. Invalidate sessions on password change or logout.
 - 3. Rate Limiting & Bot Protection:** Enforce strict IP and account rate limiting on login, signup, and reset routes with exponential backoff. Add Cloudflare Turnstile bot protection.
 - 4. Database Row Level Security (RLS):** Enable RLS on all Supabase tables. Enforce strict auth.uid() scoping. Never trust client-side role assertions for privileged operations.
 - 5. Server-Side Input Validation:** Validate all API request payloads against strict Zod schemas before processing.
 - 6. Secret Isolation:** Keep the Supabase service_role key exclusively in server environments. Never prefix server keys with NEXT_PUBLIC_.
 - 7. IDOR / BOLA Prevention:** Scope all resource queries (profiles, progress, tests) to the authenticated user ID on the server.

5. VERIFICATION COMMANDS EXECUTED

```
$ npm audit # Result: 0 vulnerabilities
$ npx tsc --noEmit # Result: 0 errors (clean strict compile)
$ npm run build # Result: 92 static/dynamic routes compiled
$ npx tsx scripts/verify-full-security-rls.mjs # Result: 22/22 PASSED
$ node scripts/test-live-security-access.mjs # Result: 23/23 PASSED
$ node scripts/test-dynamic-live-instances.mjs# Result: 15/15 PASSED
```

FINAL SECURITY GATE VERDICT: PASS / READY FOR PHASE 3

Phase 2 codebase meets all transport, dependency, code quality, and baseline security requirements.
Technical readiness confirmed to proceed toward Phase 3 authentication architecture.